

Annex 2 – DITO Data Outsourcing and Information Security Agreement

We hereby state that we read and fully understand this Annex 3 – DITO Data Outsourcing and Information Security Agreement (DOISA). All items that we cannot comply in this DOISA are listed down in the submitted “Annex C-1 -Terms of Reference Compliance Sheet” .		
<u>3E Hitech Solutions Inc.</u>	 <u>Benedict Cabrera</u>	<u>April 10, 2026</u>
Company Name	Signature over Printed Name of Authorized Representative	Date
		Corporate Seal (If any)

DITO TELECOMMUNITY CORPORATION **Data Outsourcing and Information Security Agreement**

This **Data Outsourcing and Information Security Agreement**, dated 10th of April 2026, is executed by and between:

DITO Telecommunity Corporation (“DITO”), an entity existing under and by virtue of the laws of the Republic of the Philippines, with principal office address at 11th Floor, Udenna Tower, Rizal Drive corner 4th Avenue, Bonifacio Global City, Taguig City 1634, represented herein by [insert name of representative], in his capacity as [insert designation or position];

and

3E Hitech Solutions, Inc. (“3E”), a corporation duly organized and existing under the laws of the Republic of the Philippine, with business address at Richview Residences, No. 33 Ortigas St. Brgy. 076 Pasay City, Metro Manila, NCR 1300. represented herein by herein by Benedict P. Cabrera, in his capacity as Sales Account Manager.

The Parties are hereafter referred collectively to as the “Parties” and, individually, as a “Party.”

WHEREAS, the Parties entered into the DITO Data Outsourcing and Information Security Agreement dated 10 of April 2026 (the “Agreement”);

WHEREAS, the Agreement stipulates that the SERVICE PROVIDER shall [insert services]; and

WHEREAS, the Agreement inevitably involves the collection and processing of personal data by the SERVICE PROVIDER on behalf of DITO.

NOW THEREFORE, the Parties agree as follows:

1. **Nature of this Data Outsourcing Agreement**

Annex 2 – DITO Data Outsourcing and Information Security Agreement

This Data Outsourcing Agreement and Information Security Agreement is a supplement to the Agreement and forms an integral part thereof. Where the terms in relation to data privacy of the Agreement and this Data Outsourcing and Information Security Agreement are in conflict, this Data Outsourcing and Information Security Agreement shall prevail.

2. **Term of the Data Outsourcing Agreement**

Unless otherwise stated in **Appendix 1**, this Data Outsourcing and Information Agreement shall be coterminous with the Agreement.

3. **Adherence to the Data Privacy Act of 2012**

The Parties hereby adhere to the provisions of Republic Act No. 10173, otherwise known as the Data Privacy Act of 2012, its Implementing Rules and Regulations, and the issuances of the National Privacy Commission (collectively, the “DPA”), recognizing the importance of appropriate privacy protections for its Data Subjects.

4. **Definitions**

- 4.1 The terms “Personal Information,” “Sensitive Personal Information,” “Personal Data,” “Data Subject,” “Processing,” “Personal Information Controller, and “Personal Information Processor” shall have the same meaning as set forth in the Implementing Rules and Regulations of the Data Privacy Act of 2012, as may be amended or supplemented from time to time.
- 4.2 “Data Outsourcing” is the disclosure or transfer of personal data by a personal information controller to a personal information processor. This shall also contemplate any processing performed by a personal information processor on behalf of the personal information controller.
- 4.3 “Security incident” is an event or occurrence that affects or tends to affect data protection, or may compromise the availability, integrity, and confidentiality of personal data. It includes incidents that would have resulted to a personal data breach, if not for safeguards that have been put in place.
- 4.4 “Personal data breach” refers to a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data transmitted, stored, or otherwise processed. A personal data breach may be in the nature of:
 - An availability breach resulting from loss, accidental or unlawful destruction of Personal Data.
 - Integrity breach resulting from alteration of Personal Data; and/or
 - A confidentiality breach resulting from the unauthorized disclosure of or access to Personal Data.
- 4.5 “Technical, Physical, and Organizational Security Measures” refer to those measures aimed at protecting Personal Data transmitted, stored, or otherwise processed against improper, unauthorized, accidental or unlawful processing, destruction or loss, disposal,

Annex 2 – DITO Data Outsourcing and Information Security Agreement

alteration, disclosure, or access, and against all other unauthorized and unlawful forms of processing.

5. Roles of the Parties

- 5.1 DITO is the Personal Information Controller of the Personal Data disclosed to the SERVICE PROVIDER. The SERVICE PROVIDER is a Personal Information Processor, i.e., it processes the Personal Data upon the instruction of DITO.
- 5.2 In the event that either party takes on the role of a Personal Information Controller or Personal Information Processor as defined under the DPA, such party herein undertakes to implement the necessary measures, and execute its role as Personal Information Controller or Personal Information Processor, as the case may be, in relation to any Personal Data which comes into its possession by virtue of this Agreement, in accordance with the DPA.

6. Personal Data to be Collected and Processed

- 6.1 The SERVICE PROVIDER shall process only the Personal Data listed in **Appendix 1** in accordance with the terms of the Agreement. Without need of amending this Data Outsourcing Agreement, DITO may, at any time, modify such list by written instructions to the SERVICE PROVIDER, which instructions the SERVICE PROVIDER undertakes to promptly implement in accordance with the Agreement and this Data Outsourcing Agreement.
- 6.2 The terms of this Data Outsourcing Agreement shall apply to Personal Data in all its forms. It may be on paper, stored electronically, held on film, microfiche, or other media. It shall include text, pictures, audio, and video. It shall cover information transmitted by post, by electronic means, and by oral communication, including telephone and voicemail. It shall apply throughout the lifecycle of the Personal Data, from creation, collection, storage, utilization, to disposal. The terms of this Data Outsourcing Agreement shall apply to all officers, employees, and subcontractors of both Parties where they are performing their duties in relation to the Agreement.

7. Purposes of Processing

- 7.1 The SERVICE PROVIDER shall process the Personal Data only for the purposes listed in **Appendix 1**.
- 7.2 Without need of amending this Data Outsourcing and Information Security Agreement, DITO may, at any time, modify such list by written instructions to the SERVICE PROVIDER, which instructions the SERVICE PROVIDER undertakes to promptly implement in accordance with the Agreement and this Data Outsourcing Agreement.
- 7.3 DITO may, at any time and upon written instructions to the SERVICE PROVIDER, require the SERVICE PROVIDER to process the Personal Data pursuant to and consistent with the following purposes:
 - Comply with statutory and regulatory requirements, including directives, issuances by, or obligations of DITO to any competent authority, regulator, supervisory body, enforcement agency, exchange, court, quasi-judicial body, or tribunal.

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- Enable DITO to exercise sound corporate governance over its operations, ensure that risks arising therefrom are duly identified, measured, managed, and mitigated, and enhance risk assessment and prevent fraud.
- Enable DITO to conduct audits or investigate a complaint or security threat.
- Other legitimate business purposes of DITO.
- Establish, exercise, or defend the DITO's legal claims; and
- Fulfill any other purposes directly related to the above-stated purposes.

8. **Geographic Location of the Processing**

- 8.1 The Personal Data shall be processed by the SERVICE PROVIDER at the geographic location specified in **Appendix 1**.
- 8.2 The SERVICE PROVIDER shall, at least thirty (30) days prior to effecting any change in the geographic location, notify DITO in writing of such intended change and provide reasonable proof that such change shall not adversely affect the privacy and information security measures currently in place or impact the privacy rights of the Data Subjects.
- 8.3 DITO reserves the right to immediately terminate the Agreement and this Data Outsourcing and Information Security Agreement should the SERVICE PROVIDER fail to notify DITO within the period stated, or, in DITO's discretion and assessment, fail to provide reasonable proof that such change shall not adversely affect the privacy and information security measures currently in place or impact the privacy rights of the Data Subjects.

9. **Obligation of DITO**

DITO shall be obliged to specify the persons and/or entities authorized to receive, access, process, and/or transmit the information obtained and processed by the SERVICE PROVIDER. The SERVICE PROVIDER may refuse to give information to persons or entities not designated by DITO.

10. **Data Privacy Obligations of the SERVICE PROVIDER**

Pursuant to the requirements of the DPA and DITO, the SERVICE PROVIDER hereby warrants that, at the minimum, it has established or shall establish the following data privacy measures:

10.1 **General Privacy Requirements**

- 10.1.1 That the SERVICE PROVIDER shall have a privacy management program in place.
- 10.1.2 That the SERVICE PROVIDER shall have its data processing systems registered with the National Privacy Commission (NPC), where the Service Provider is subject to mandatory registration under NPC Circular No. 2017-01.
- 10.1.3 That the SERVICE PROVIDER shall have a record of processing activities, with such record containing the following information:
- 10.1.3.1 Information about the purpose of the processing of Personal Data, including any intended future processing or data sharing;

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 10.1.3.2 A description of all categories of data subjects, Personal Data, and recipients of such personal data that will be involved in the processing;
 - 10.1.3.3 General information about the data flow within the organization, from the time of collection, processing, and retention, including the time limits for disposal or erasure of personal data;
 - 10.1.3.4 A general description of the organizational, physical, and technical security measures in place; and
 - 10.1.3.5 The name and contact details of the SERVICE PROVIDER and, where applicable, the joint controller, its representative, and the compliance officer or data protection officer, or any other individual or individuals accountable for ensuring compliance with the applicable laws and regulations for the protection of data privacy and security.
- 10.1.4 That the SERVICE PROVIDER shall designate an individual or individuals who shall function as data protection officer.
- 10.1.5 That the SERVICE PROVIDER shall adhere to and comply with the DPA and the terms set forth in the Agreement and this Data Outsourcing and Information Security Agreement as executed between DITO and the SERVICE PROVIDER.

10.2 General Data Protection Policies and Procedures

- 10.2.1 That the SERVICE PROVIDER shall implement data protection policies that provide for organizational, physical, and technical security measures, and, for such purpose, take into account the nature, scope, context and purposes of the processing, as well as the risks posed to the rights and freedoms of data subjects. These policies shall:
- 10.2.1.1 Implement data protection principles both at the time of the determination of the means for processing and at the time of the processing itself.
 - 10.2.1.2 Implement appropriate security measures that, by default, ensure only personal data which is necessary for the specified purpose of the processing are processed. They shall determine the amount of personal data collected, the period of their storage, and their accessibility.
 - 10.2.1.3 Provide for documentation, regular review, evaluation, and updating of the privacy and security policies and practices.
- 10.2.2 That the SERVICE PROVIDER shall implement policies and procedures regarding the transfer, removal, disposal, and re-use of electronic media.

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 10.2.3 That the SERVICE PROVIDER shall implement a security policy with respect to the processing of Personal Data.

10.3 Management of Human Resources

- 10.3.1 That the SERVICE PROVIDER shall have policies and procedures in place for selecting and supervising its employees, agents, or representatives, particularly those who will have access to the Personal Data transferred or disclosed by, or other processed on behalf of, DITO.
- 10.3.2 That the SERVICE PROVIDER's employees, agents, or representatives processing the personal data transferred or disclosed by, or otherwise processed on behalf of DITO shall operate and hold such personal data under strict confidentiality if the personal data are not intended for public disclosure.
- 10.3.3 That the SERVICE PROVIDER shall provide its employees, agents, or representatives training on data privacy, with the main objective of clearly communicating the policies, procedures, and the roles and responsibilities of such employees, agents, or representatives in relation to data privacy. Such training shall be held at least twice a year.

10.4 Access Control Management

- 10.4.1 That the SERVICE PROVIDER shall strictly regulate access to the personal data transferred or disclosed by, or otherwise processed on behalf of, DITO. Such access shall be granted through the issuance of a security clearance, with such clearance being issued only when the performance of a service for DITO directly depends on such access or cannot otherwise be performed without such access. A copy of each security clearance must be filed with the SERVICE PROVIDER's data protection officer.
- 10.4.2 That the SERVICE PROVIDER shall restrict access to any of the personal data transferred or disclosed by, or otherwise processed on behalf of DITO to authorized individuals.
- 10.4.3 That the SERVICE PROVIDER shall have policies and procedures that shall be implemented to monitor and limit access to and activities in the room, workstation, or facility where the personal data transferred or disclosed by, or otherwise processed on behalf of DITO is being processed, including guidelines that specify the proper use of and access to electronic media.
- 10.4.4 That the SERVICE PROVIDER shall ensure that the duties, responsibilities, and schedule of individuals involved in the processing of personal data are clearly defined to ensure that only the individuals actually performing official duties shall be in the room or in the work station where the personal data is being processed, at any given time.

10.5 Encryption of Personal Data

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 10.5.1 That the SERVICE PROVIDER shall ensure that all personal data transferred or disclosed by, or otherwise processed on behalf of DITO shall be encrypted during storage and while in transit. For this purpose, Advanced Encryption Standard with a key size of 256 bits (AES-256) shall be used.
- 10.5.2 That the SERVICE PROVIDER shall ensure that all transmitted records and files containing personal data that will travel across public networks or through wireless means shall be encrypted.
- 10.5.3 That the SERVICE PROVIDER shall ensure encryption of all personal data stored on laptops or other portable devices.
- 10.5.4 That the SERVICE PROVIDER shall develop and implement a password policy that would ensure that passwords or passphrase used to access personal data shall be of sufficient strength to deter password attacks.
- 10.5.5 That the SERVICE PROVIDER shall ensure that personal data transferred via email shall be encrypted. The passwords for email attachments containing personal data should be sent in a separate email.

10.6 Privacy and Data Protection in Operations

- 10.6.1 That the SERVICE PROVIDER shall only process the personal data transferred or disclosed by, or otherwise processed on behalf of, DITO only upon the documented instructions of DITO, including transfers of such personal data to another country or to an international organization, unless such transfer is authorized by law.
- 10.6.2 That the SERVICE PROVIDER shall have visible and accessible privacy notices or privacy statements that contains all such necessary disclosures as identified in Sec. 16(b) of the Data Privacy Act of 2012.
- 10.6.3 That, where the SERVICE PROVIDER directly receives personal data from a data subject for processing, the SERVICE PROVIDER shall obtain recorded consent prior to the processing of such personal data. This requirement shall, however, be subject to the exclusions provided for by the DPA, other applicable laws and regulations, and the written agreement, data outsourcing agreement, or data sharing agreement as executed between DITO and the SERVICE PROVIDER.

The consent mechanism shall, at the minimum, contain the following information:

- 10.6.3.1 A description of the personal information to be processed or the types of personal data located;
- 10.6.3.2 The purposes for which they are being or are to be processed;
- 10.6.3.3 The scope and method of the personal information processing;

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 10.6.3.4 The recipients or classes recipients to whom they are or may be disclosed;
- 10.6.3.5 Methods utilized for automated access, if the same is allowed by the data subject, and the extent to which such access is authorized;
- 10.6.3.6 The contact details of the SERVICE PROVIDER and its data protection officer;
- 10.6.3.7 The period for which personal data shall be stored; and
- 10.6.3.8 The rights of the data subject.
- 10.6.4 That the SERVICE PROVIDER shall post a privacy notice or a privacy statement on their online platforms or websites when the same:
 - 10.6.4.1 Collects personal data through web forms, feedback forms, or similar mechanisms;
 - 10.6.4.2 Uses cookies, web beacons, or other passive technologies that collect and process personal data; or
 - 10.6.4.3 Covertly collects personal data.
- 10.6.5 That, when the processing of the personal data received directly by the SERVICE PROVIDER shall be processed beyond what the data subject has consented to, the SERVICE PROVIDER shall procure the consent of the data subject.
- 10.6.6 That the SERVICE PROVIDER shall only process the personal data transferred or disclosed by, or otherwise processed on behalf of DITO for a specific period of time relevant to the purpose upon which such personal data has been collected for, subject to the written agreement, data outsourcing agreement, or data sharing agreement as executed between DITO and the SERVICE PROVIDER.
- 10.6.7 That, whenever appropriate, any request from a data subject pursuant to the exercise of the rights of a data subject shall be documented by the SERVICE PROVIDER.
- 10.6.8 That the SERVICE PROVIDER shall have a policy that would allow data subjects to exercise their rights under the DPA.
- 10.6.9 That the SERVICE PROVIDER shall assist DITO, by appropriate technical and organizational measures and to the extent possible, fulfill the obligation to respond to requests by data subjects relative to the exercise of their rights.
- 10.6.10 That the SERVICE PROVIDER shall have a process for processing and retaining personal data for only a limited period until the purposes for the processing have

Annex 2 – DITO Data Outsourcing and Information Security Agreement

been achieved and ensuring that such personal data is securely destroyed or disposed of.

- 10.6.11 That the SERVICE PROVIDER shall not store the personal data transferred or disclosed by, or otherwise processed on behalf of DITO on removable media (e.g. USB flash drives, thumb drives, memory sticks, tapes, CDs, or external hard drives) except for backup, business continuity, disaster recover, and data interchange purposes as allowed and required under the applicable agreement between DITO and the SERVICE PROVIDER.
- 10.6.12 That physical forms and documents containing personal data transferred or disclosed by, or otherwise processed on behalf of DITO shall be stored in physical vaults for long-term storage, or within sealed envelopes or containers for short-term storage or during transfers between physical locations. The physical container or repository shall only be accessed by authorized SERVICE PROVIDER personnel and shall always be locked when not being accessed. Access to the physical vaults, containers, or repositories containing such personal data shall be logged by the owner or the custodian of the facility.
- 10.6.13 That, for any project, platform, or engagement that may require the processing of personal data transferred or disclosed to, or otherwise processed by, the SERVICE PROVIDER on behalf of DITO, such project, platform, or engagement must be carried out or implemented in a DITO-managed environment and not on a third-party-managed environment. However, if the processing of such personal data in a third party-managed environment is unavoidable, the following requirements must be satisfied:
 - 10.6.13.1 The personal data to be processed must be anonymized to the extent possible prior to the transfer of the personal data. DITO will retain possession of the anonymization key. If the personal data cannot be anonymized on account of the nature of the transaction, the processing of such personal data must be approved by the Board of Directors through a deviation request upon the recommendation of the Information Security Officer and the Data Protection Officer of DITO.
 - 10.6.13.2 The third party-managed environment must comply with the requirements identified by DITO and must likewise be compliant with the applicable data privacy laws in the Philippines.
- 10.6.14 That the SERVICE PROVIDER shall ensure that the design of its office spaces and work stations, including the physical arrangement of the furniture and equipment, shall provide privacy to anyone processing personal data, taking into consideration the environment and the accessibility to the public.
- 10.6.15 That the SERVICE PROVIDER shall have policies and procedures that prevent the mechanical destruction of files and equipment involved in the processing of personal data.

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 10.6.16 That the SERVICE PROVIDER shall ensure that the room, workstation, or facility used in the processing of personal data shall, as far as practicable, be secured against natural disasters, power disturbances, external access, and other similar threats.
- 10.6.17 That the SERVICE PROVIDER shall ensure that safeguards are present to protect its computer network against accidental, unlawful or unauthorized usage, any interference that will affect data integrity or hinder the functioning or availability of such system, and unauthorized access through an electronic network.
- 10.6.18 That the SERVICE PROVIDER shall ensure that it can ensure and maintain the confidentiality, integrity, availability, and resilience of personal data processing systems and services.
- 10.6.19 That the SERVICE PROVIDER shall ensure that it shall implement the appropriate security measures in relation to the processing of personal data, and that it shall comply with the DPA.

10.7 Security Incident and Personal Data Breach Management

- 10.7.1 That the SERVICE PROVIDER shall develop and implement a security incident management policy, which shall include an incident response procedure intended to contain a security incident or personal data breach.
- 10.7.2 That the SERVICE PROVIDER shall create and maintain a data breach response team.
- 10.7.3 That the SERVICE PROVIDER shall notify DITO within twenty-four (24) hours from actual knowledge of or reasonable belief that a security incident or a personal data breach involving the personal data transferred or disclosed by, or otherwise processing on behalf of DITO has occurred.
- 10.7.4 That the SERVICE PROVIDER, after notifying DITO of such security incident or personal data breach, shall provide DITO with regular status updates, with such updates including information on, but not limited to, the following:
 - 10.7.4.1 Nature of the breach or the incident
 - 10.7.4.1.1 description of how the incident or breach occurred and the vulnerability of the data processing system that allowed the breach;
 - 10.7.4.1.2 a chronology of the events leading up to the loss of control over the personal data;
 - 10.7.4.1.3 approximate number of data subjects or records involved;
 - 10.7.4.1.4 description or nature of the personal data breach;

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 10.7.4.1.5 description of the likely consequences of the personal data breach; and
 - 10.7.4.1.6 name and contact details of the data protection officer or any other accountable persons.
 - 10.7.4.2 Personal data possibly involved
 - 10.7.4.2.1 description of sensitive personal information involved; and
 - 10.7.4.2.2 description of other information involved that may be used to enable identity fraud.
 - 10.7.4.3 Measures taken to address the breach or the incident
 - 10.7.4.3.1 description of the measures taken or proposed to be taken to address the breach;
 - 10.7.4.3.2 actions being taken to secure or recover the personal data that were compromised;
 - 10.7.4.3.3 actions performed or proposed to mitigate possible harm or negative consequences, and limit the damage or distress to those affected by the incident; and
 - 10.7.4.3.4 the measures being taken to prevent a recurrence of the incident.
- 10.7.5 That the SERVICE PROVIDER shall submit a report, annually or upon request, that would document all security incidents and personal data breaches that took place prior to the request and within the year. Such report shall include:
 - 10.7.5.1 The facts surrounding the incident;
 - 10.7.5.2 The effects of such incident; and
 - 10.7.5.3 The remedial action taken by the SERVICE PROVIDER.
- 10.7.6 That the SERVICE PROVIDER shall extend all assistance without undue delay to the Data Protection Officer of DITO in managing and resolving security incidents that resulted or may result in a personal data breach.
- 10.7.7 That the SERVICE PROVIDER shall cooperate in any investigation conducted by the NPC in relation to any data breach or security incident involving the personal data transferred or disclosed by, or otherwise processed on behalf of DITO.

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 10.7.8 That the SERVICE PROVIDER shall conduct regular monitoring for security incidents and personal data breaches, and shall likewise develop and implement a process for identifying and accessing reasonably foreseeable vulnerabilities in its computer networks, and for taking preventive, corrective, and mitigating action against security incidents that can lead to a personal data breach.
- 10.7.9 That the SERVICE PROVIDER shall ensure that it can restore the availability and access to personal data in a timely manner in the event of a physical or technical incident.

10.8 Compliance and Risk Management

- 10.8.1 That the SERVICE PROVIDER shall adhere to the Privacy Impact Assessment (PIA) procedures as established or used by DITO. It shall comply with all PIA-related activities as initiated by DITO.
- 10.8.2 That the SERVICE PROVIDER shall exercise utmost care to protect the privacy, confidentiality, integrity, and availability of the personal data transferred or disclosed by, or processed on behalf of DITO against events such as unauthorized disclosure, unlawful surveillance, privacy violations, and other undesirable events.
- 10.8.3 That the SERVICE PROVIDER shall implement the necessary measures to ensure that it meets the legal and regulatory requirements applicable to DITO such as, but not limited to, the Data Privacy Act of 2012.
- 10.8.4 That the SERVICE PROVIDER shall establish a process to monitor its enforcement of its privacy program and drive the continuous improvement of the same.
- 10.8.5 That the SERVICE PROVIDER shall ensure that it has a process for regularly testing, assessing, and evaluating the effectiveness of security measures.
- 10.8.6 That the SERVICE PROVIDER shall make available to DITO all information necessary to demonstrate compliance with the obligations laid down in the Data Privacy Act of 2012.
- 10.8.7 That the SERVICE PROVIDER shall allow for and contribute to audits, including inspections, as conducted by DITO or another auditor as mandated by the latter. The audit shall be limited to the processing systems related to the personal data transferred or disclosed by, or otherwise processed on behalf of DITO.
- 10.8.8 That the SERVICE PROVIDER shall immediately inform DITO if, in its opinion, an instruction infringes the DPA.

10.9 Further Outsourcing or Subcontracting the Processing of Personal Data

- 10.9.1 That the SERVICE PROVIDER shall not engage a sub-processor or subcontractor for the purpose of processing the personal data transferred or

Annex 2 – DITO Data Outsourcing and Information Security Agreement

disclosed by, or otherwise processed on behalf of DITO without prior instruction from DITO.

- 10.9.2 That, where DITO permits the SERVICE PROVIDER to further outsource or subcontract the processing of personal data, the subcontractor or sub-processor engaged by the SERVICE PROVIDER shall abide by the same obligations for data protection under the appropriate agreement between DITO and the SERVICE PROVIDER.
- 10.9.3 That, where DITO permits the SERVICE PROVIDER to further outsource or subcontract the processing of personal data to a third party, the SERVICE PROVIDER shall ensure that such third party shall also implement the security measures as required by the DPA.
- 10.9.4 That the SERVICE PROVIDER shall only process the personal data transferred or disclosed to it by DITO for the purposes set forth in the written agreement, data outsourcing agreement, or data sharing agreement as executed between DITO and the SERVICE PROVIDER.
- 10.9.5 That the SERVICE PROVIDER shall take steps to review contracts or agreements with subcontractors and/or sub-processors to ensure that such agreements are compliant with the Data Privacy Act of 2012.
- 10.9.6 That, in case the SERVICE PROVIDER were to receive personal data directly from a data subject, the SERVICE PROVIDER shall conduct a review and assessment of its data collection forms to determine whether the consent of such data subject, where applicable, has been secured.
- 10.9.7 That the SERVICE PROVIDER shall monitor emerging technologies, new risks in personal data processing, and the privacy ecosystem.
- 10.9.8 That the SERVICE PROVIDER shall keep track of data privacy best practices, sector-specific standards, and international data protection standards.
- 10.9.9 That, where necessary, the SERVICE PROVIDER shall seek the guidance and legal opinions on the issuances or requirements of the NPC.

10.10 Deletion or Return of the Personal Data

That, upon termination of the agreement between DITO and the SERVICE PROVIDER that permitted the processing of personal data, the SERVICE PROVIDER, without need for demand and at the choice of DITO, shall delete or return all personal data to DITO. This shall include the deletion of all existing copies of the personal data unless the storage of such personal data is authorized by the Data Privacy Act of 2012 or another law. The deletion herein shall include the deletion of temporary files created as a result of the processing of personal data.

11. Information Security Obligations of the SERVICE PROVIDER

Annex 2 – DITO Data Outsourcing and Information Security Agreement

Pursuant to its obligation to maintain the appropriate Technical, Physical, and Organizational Security Measures, the SERVICE PROVIDER warrants, at the minimum and where applicable, that it has established or shall establish the following information security measures:

11.1 General Security Measures

- 11.1.1 That network access shall be enforced by a written agreement or contract in which the rights and duties of DITO and the SERVICE PROVIDER are specified. The same agreement or contract shall always have non-disclosure provisions that indicate the responsibilities of the SERVICE PROVIDER in using or processing DITO data and the limited scope upon which the use and processing of information is allowable.
- 11.1.2 That the SERVICE PROVIDER shall sign a written agreement or contract with the appropriate non-disclosure clauses or a separate non-disclosure agreement, either of which will require the inclusion of the following clauses:
 - 11.1.2.1 That the information shall be kept confidential and shall be used only for the purposes specified;
 - 11.1.2.2 That confidentiality undertakings shall be secured for all the SERVICE PROVIDER's employees who will have access to DITO's information;
 - 11.1.2.3 That no access to DITO's information is given to another party or any agency staff, contract worker, or any other similar individual without obtaining prior written permission from DITO and securing confidentiality undertaking from the agency and/or the contract worker concerned;
 - 11.1.2.4 That access and system activities shall be limited to the purpose set forth in the Agreement, the Statement of Work (SOW), or in the Data Outsourcing and Information Security Agreement, whichever is applicable;
 - 11.1.2.5 That all applicable legislation, codes of conduct, or similar provisions requiring protection of subscriber information shall be complied with;
 - 11.1.2.6 That the recommendations and best practices of the Office of the Information Security Officer (ISO) of DITO to ensure information security shall be complied with;
 - 11.1.2.7 That the periodic inspection of SERVICE PROVIDER's security infrastructure including sites, premises, and hardware and network security checks by the Office of the ISO of DITO shall be allowed; and
 - 11.1.2.8 That the minimum security imposed by DITO through written agreements shall be adhered to.

Annex 2 – DITO Data Outsourcing and Information Security Agreement

11.2 Information Security Organization

- 11.2.1 That the SERVICE PROVIDER shall designate and appoint an Information Security Officer who will coordinate with the Office of the ISO of DITO on any matters concerning information security.
- 11.2.2 That the SERVICE PROVIDER shall have a dedicated and competent information security team that will oversee the implementation and enforcement of the information security programs of the SERVICE PROVIDER.
- 11.2.3 That the SERVICE PROVIDER shall ensure that its information security team has the reasonable and necessary experience and training in information security management.
- 11.2.4 That the SERVICE PROVIDER shall provide annually to DITO an organizational diagram outlining the roles and responsibilities of all individuals implementing and enforcing the information security programs of the SERVICE PROVIDER.
- 11.2.5 That the SERVICE PROVIDER shall periodically measure its information security program and shall implement and maintain a mature information security program in accordance with industry best practices.

11.3 Information Security Policy

- 11.3.1 That the SERVICE PROVIDER shall recognize the Cyber and Information Security Policy (CIS Policy) of DITO and that it shall ensure its strict enforcement in the SERVICE PROVIDER's site and organization. At the minimum, the SERVICE PROVIDER must have:
 - 11.3.1.1 An established and approved information security policy of its own that meets DITO's CIS Policy;
 - 11.3.1.2 Record of Acknowledgement of DITO's CIS Policy and
 - 11.3.1.3 Enforced policy-violation prevention and detection program, including an anti-fraud program.
- 11.3.2 That the SERVICE PROVIDER shall maintain a comprehensive set of published and enforced security policies that have been presented to DITO. Any subsequent amendments shall be presented to DITO.

11.4 Human Resource Security

- 11.4.1 That the SERVICE PROVIDER shall include a training program on social engineering, at least once every year.

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 11.4.2 That, prior to granting any person with direct or indirect access—whether physical, virtual, or otherwise—to any of DITO's company, employee, or customer information, or any of DITO's premises, systems or software, or networks, the SERVICE PROVIDER shall perform a background check and verify the identity of such person (employee, contractor, or subcontractor including on-site security guards responsible for physical security of SERVICE PROVIDER premises and DITO restricted areas, and unescorted cleaning/maintenance personnel) and to determine whether such person has a conflict of interest. If there is such conflict of interest, DITO shall be notified immediately of the same in writing.
- 11.4.3 That a security plan shall be in place to include the training of SERVICE PROVIDER personnel to report any suspicious activity or security incidents and complaints that did or could affect DITO, with documentation and follow-up to the Office of the ISO of DITO and, when necessary, law enforcement.
- 11.4.4 That the SERVICE PROVIDER shall give proper training to their employees before allowing them to operate and access the systems/applications of DITO to lessen operational risks (e.g. human error).
- 11.4.5 That all existing employees who have not signed a non-disclosure agreement (NDA) yet shall do so within the agreed period. Employees who will not be willing to sign the NDA will be asked to draft a letter addressed to HR explaining why he/she does not want to sign the NDA. The HR leadership will determine the merits of the latter and determine how to proceed.
- 11.4.6 That the SERVICE PROVIDER shall ensure that its staff will not perform any duties incompatible to the fulfillment of his or her roles and responsibilities. For example, maker and checker roles are incompatible, and must, therefore, not be assigned to the same person.
- 11.4.7 That the SERVICE PROVIDER shall establish and document the information security roles and responsibilities of their employees and non-employees.
- 11.4.8 That the SERVICE PROVIDER shall provide formal induction training on information security with the main objective of clearly communicating the policies and procedures, including the personnel responsibilities on information security.
- 11.4.9 That the SERVICE PROVIDER shall keep, document, and maintain a record of the following:
 - 11.4.9.1 Employee-signed acknowledgement form of the SERVICE PROVIDER's information security policy;
 - 11.4.9.2 Staff attendance record on information security training;
 - 11.4.9.3 Employee-signed system access request form; and

Annex 2 – DITO Data Outsourcing and Information Security Agreement

11.4.9.4 Employee and visitor logbook.

The minimum required retention period of the foregoing shall be twelve (12) months from the time such record was created.

11.4.10 That the SERVICE PROVIDER shall develop and implement an information security awareness program on a monthly basis and provide continuous information security training to all of SERVICE PROVIDER employees. The training must be relevant to the roles that the employees are assuming.

11.4.11 That, upon the termination of the relationship between the SERVICE PROVIDER and any of its employees that has business with DITO, all access to facilities and information resources shall cease.

11.4.12 That, in the case of unfriendly termination, DITO reserves the right to disallow and disable all physical and technical access without prior notification.

11.5 Information Asset Management

11.5.1 That all electronically stored or printed DITO information that are no longer needed must be securely shredded on-site or destroyed on-site by authorized SERVICE PROVIDER personnel assigned to DITO projects. Shred bins must be in restricted areas and locked until the shredding takes place.

11.5.2 That the SERVICE PROVIDER shall ensure that DITO's information are, whenever practicable, labelled as "DITO Proprietary Information" or at a minimum, as "Confidential" or "Proprietary". The SERVICE PROVIDER shall acknowledge that DITO's information shall remain DITO-owned information irrespective of its label or the absence thereof. The SERVICE PROVIDER shall likewise recognize DITO as the rightful owner of the information that may be obtained and produced by the SERVICE PROVIDER in connection with the delivery of services.

11.6 Access Control Management

11.6.1 That the SERVICE PROVIDER shall assign unique user IDs to individual users. User IDs and its corresponding passwords should only be used by the person to whom they have been issued. It should not be loaned or shared with any other person.

11.6.2 That the SERVICE PROVIDER shall restrict the use of any access granted by DITO to its systems only for such purposes as authorized under the Agreement, to prevent misuse and abuse of such access. Procedures shall be in place to ensure that the SERVICE PROVIDER's employees' access to DITO information, systems, and applications is for the purposes of this Agreement and for no other reason.

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 11.6.3 That, where applicable, all SERVICE PROVIDER administrative and privileged user accounts shall be used only when performing duties requiring administrative or privileged access.
- 11.6.4 That, where applicable, administrative, and privileged account holders of the SERVICE PROVIDER shall have a second user account for performing any function where administrative or privileged access is not required.
- 11.6.5 That, where applicable, all SERVICE PROVIDER user accounts that require administrative or privileged access will be enabled according to a documented schedule and/or a formal request and shall be disabled at all other times.
- 11.6.6 That the authority to access DITO information shall be reviewed by the SERVICE PROVIDER's identity access management administrator or an individual with a similar authority, the accessing personnel's immediate superior, and the business group head to which the personnel belongs on a regular basis.
- 11.6.7 That the SERVICE PROVIDER shall notify DITO of the names of their separated, terminated or transferred personnel with access to the latter's systems or applications within twenty-four (24) hours from such separation, termination, or transfer.
- 11.6.8 That DITO has the right to revoke the access of the SERVICE PROVIDER or any of its personnel's access without notice.
- 11.6.9 That the SERVICE PROVIDER shall not perform any means to circumvent the security mechanisms in place or exploit vulnerabilities present in DITO's systems or applications.

11.7 **Cryptography**

- 11.7.1 That strong encryption shall be used to electronically transmit DITO proprietary information. The SERVICE PROVIDER shall confirm that a process is in place to randomly check SERVICE PROVIDER-based email and internet-based email so that DITO information is not sent to unauthorized recipients. Any unauthorized transmissions must be reported to the Office of the ISO and the DPO within twenty-four (24) hours from knowledge of or reasonable belief that such unauthorized transmission occurred.
- 11.7.2 That, when customer data is entered through a website, the SERVICE PROVIDER should encrypt that Information using Secure Sockets Layer technology (SSL) so that the information cannot be read as it travels over the internet.
- 11.7.3 That all confidential DITO information collected by the SERVICE PROVIDER through digital, manual, or any other means of collection shall be immediately masked during display and upon storage.

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 11.7.4 That passwords or passphrases used to access DITO information should be of sufficient strength to deter password attacks. A password policy should be issued and enforced through a system management tool.

11.8 Communications Security

- 11.8.1 That, for files containing DITO information on a system that is connected to the internet, there shall be reasonably up-to-date firewall protection and operating system security patches, reasonably designed to maintain the integrity of the DITO information.
- 11.8.2 That the SERVICE PROVIDER shall deploy redundant network components for its network connections with DITO.
- 11.8.3 That the SERVICE PROVIDER shall perform periodic revalidations on the user account list on firewalls, firewall management servers, and firewall hop boxes to ensure that only those users authorized for access to manage these devices have an account. This shall include the need to revalidate the authorization level of each user account to ensure that appropriate permission levels are maintained. Production support personnel and development personnel must have enough separation and auditable controls to ensure that standard change management procedures are always consistently followed.
- 11.8.4 That the SERVICE PROVIDER must implement procedures to ensure that DITO information is not downloaded and removed by SERVICE PROVIDER resources, including at a minimum, searches of persons and their belongings when exiting SERVICE PROVIDER's restricted areas or the SERVICE PROVIDER's premises. It is recommended that a respected external access control SERVICE PROVIDER (such as Websense) be engaged to meet the network component of this control.
- 11.8.5 That, if authorized to download DITO information to the SERVICE PROVIDER's system, the SERVICE PROVIDER shall employ equivalent levels of security, which shall include the following measures:
 - 11.8.5.1 Access and usage should be recorded, monitored and audited;
 - 11.8.5.2 Data residing on SERVICE PROVIDER's servers should be backed up to ensure availability and restoration in times of system failure;
 - 11.8.5.3 Backups should be stored securely to provide the same level of security as the main source data;
 - 11.8.5.4 All items of equipment containing storage media should be checked; and
 - 11.8.5.5 Storage media that has been used to store or process DITO information should be disposed of securely.

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 11.8.6 That the SERVICE PROVIDER shall provide for the automatic deletion of temporary files that may be stored on a local machine by its operating system.
- 11.8.7 That, where possible, the SERVICE PROVIDER personnel shall not be allowed to save files to a local machine, and that shall be directed to only save files to their allocated network drive.
- 11.8.8 That remote access to DITO networks or DITO information is prohibited. All work on DITO projects must be performed within the DITO restricted area on SERVICE PROVIDER's premises. Any forms of "bridging" onto DITO systems such as, but not limited to, allowing access to DITO using remote desktop or emulation software or PC linked to a modem to another PC which has access to DITO systems must be prevented
- 11.8.9 The SERVICE PROVIDER shall acknowledge DITO's right to immediately suspend or terminate any interconnection if DITO, in its sole discretion, believes there has been a breach of security or unauthorized access to or misuse of DITO data facilities or information.
- 11.8.10 That the SERVICE PROVIDER shall have a documented process and controls in place to detect and handle unauthorized attempts to access DITO's information.

11.9 Operation Security

- 11.9.1 That the SERVICE PROVIDER shall have documented and up-to-date operational processes and procedures that are clearly communicated to all the concerned employees and non-employees, with such processes and procedures covering:
 - 11.9.1.1 Information Security Management;
 - 11.9.1.2 Operations Management;
 - 11.9.1.3 Task Scheduling;
 - 11.9.1.4 Shift Management;
 - 11.9.1.5 System Parameter Maintenance;
 - 11.9.1.6 Software Implementation and Control;
 - 11.9.1.7 Works Order Handling;
 - 11.9.1.8 Routine Backup and Recovery;
 - 11.9.1.9 Switching Network Monitoring and Controlling;
 - 11.9.1.10 Problem Management;

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 11.9.1.11 Media and Output Control;
 - 11.9.1.12 Preventive Maintenance; and
 - 11.9.1.13 Change Management (including backout procedures for all production environments).
- 11.9.2 That the SERVICE PROVIDER shall restrict access to security logs to authorized individuals and to protect security logs from unauthorized modification.
- 11.9.3 That the SERVICE PROVIDER shall review, on no less than a weekly basis, all security and security-related audit logs for anomalies. All logged security problems should be documented and resolved in a timely manner.
- 11.9.4 That the SERVICE PROVIDER shall retain complete and accurate records relating to its performance of its obligations arising out of DITO's security provisions in a format that will permit assessment or audit for a period of no less than twelve (12) months, or for such period as may be required pursuant to a court order or a civil or regulatory proceeding.
- 11.9.5 That the SERVICE PROVIDER shall, within thirty (30) days of receiving the due diligence report, provide DITO with a written report outlining the corrective actions that the SERVICE PROVIDER has implemented or proposes to implement with the schedule and current status of each corrective action. SERVICE PROVIDER shall update this report to DITO every thirty (30) days, reporting the status of all corrective actions through the date of implementation. SERVICE PROVIDER shall implement all corrective actions within ninety (90) days of SERVICE PROVIDER's receipt of the due diligence or audit report.
- 11.9.6 That, for any project, platform, or engagement which requires handling or processing of personal data of a DITO customer or employee, the following shall be implemented:
 - 11.9.6.1 Remote connectivity to the DITO-managed environment shall be through VPN or access gateway technologies that will enable DITO to enforce security controls required to protect DITO information such as viewing or read access only, no downloading on workstations or local disks, two-factor authentication, or any form of control that DITO deems necessary for enforcement.
 - 11.9.6.2 Remote connectivity shall not be allowed, and SERVICE PROVIDERS shall be required to be on premise for short-term engagements (analytics, consulting, POC, audits). Short-term engagements are defined as engagements that are less than three months.
 - 11.9.6.3 Remote connectivity shall only be allowed for long term engagements such as managed services and application support and it shall only be

Annex 2 – DITO Data Outsourcing and Information Security Agreement

from approved locations based on the agreements and assessments of the specific engagement

- 11.9.7 That all project teams must also be informed that third party SERVICE PROVIDERs, which have indirect or direct access to DITO information, should agree to defend, indemnify, and hold harmless DITO from and against any claims or damages relating to any third party claim concerning SERVICE PROVIDER's failure to implement the security measures required by DITO.

11.10 Incident Management

- 11.10.1 That the SERVICE PROVIDER shall have an established incident management and response program, which shall include procedures that are documented and tested annually and adequately trained staff.
- 11.10.2 That the SERVICE PROVIDER shall have an incident management process and shall promptly notify DITO whenever there is an attack upon, intrusion upon, unauthorized access to, loss of, or other breach of DITO's information resources. Such prompt notification shall not exceed twenty-four (24) hours from actual knowledge or reasonable belief that there has been such attack, intrusion, unauthorized access, or breach.
- 11.10.3 That the SERVICE PROVIDER shall, after notifying DITO whenever there is an attack upon, intrusion upon, unauthorized access to, loss of, or other breach of DITO's information resources, provide DITO with regular status updates, including, but not limited to, actions taken to resolve such incident, at mutually agreed intervals or times for the duration of the incident. Within five (5) days from the closure of the incident, the SERVICE PROVIDER shall also provide DITO with a written report describing the incident, actions taken by SERVICE PROVIDER during its response and its plans for future actions to prevent a similar incident from occurring.
- 11.10.4 That the SERVICE PROVIDER shall extend assistance without undue delay to the Office of the ISO of DITO in managing and resolving information security-related incidents.
- 11.10.5 That the SERVICE PROVIDER shall be responsible for any activities performed by its personnel on DITO's data, systems, and applications and shall develop a process for reviewing work performed by its personnel to determine the appropriateness of activities performed and checks for suspicious transactions if any.
- 11.10.6 That the SERVICE PROVIDER shall address any security leak or breach and shall implement adequate measure to prevent recurrence before connection to the DITO network is restored.

11.11 Business Continuity

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 11.11.1 That the SERVICE PROVIDER shall establish and implement Business Continuity Management process and procedures based on ISO 22301, or any equivalent BCP framework, which shall require the following measures:
 - 11.11.1.1 That backup and restoration procedures are formally documented, tested annually, and performed by trained personnel;
 - 11.11.1.2 That backup tapes and disks are encrypted for sensitive data and are kept for a minimum of six (6) months, rotated off-site for storage, and purged once the data retention point is reached;
 - 11.11.1.3 That the Business Continuity Plan (BCP) is formally documented, managed by a dedicated group, and tested on an annual basis;
 - 11.11.1.4 That users are trained on their BCP responsibilities;
 - 11.11.1.5 That a "hot site" is in place;
 - 11.11.1.6 That Redundant systems are in place with multiple data centers or warm sites; and
 - 11.11.1.7 That the duration to restore operations after an outage or loss/corruption of data must be within the limits agreed with the DITO BCP team.
- 11.11.2 That the SERVICE PROVIDER shall maintain and, upon DITO's request, furnish DITO with a documented BCP that ensures that the SERVICE PROVIDER can meet its contractual obligations under the Agreement, including the requirements of any applicable statement of work or service level agreement. Such a plan shall include the requirement that the included procedures be regularly tested at least annually. The SERVICE PROVIDER shall promptly review its business continuity plan to address additional threat scenarios.
- 11.11.3 That the SERVICE PROVIDER shall regularly test the backup and conduct backup recoverability tests to ensure they meet the requirements of the BCP.
- 11.11.4 That the SERVICE PROVIDER shall perform ongoing monitoring of the BCP and disaster recovery plans. The SERVICE PROVIDER shall implement periodic review and monitoring of compliance and preparedness through mock disaster recovery drills.
- 11.11.5 That the SERVICE PROVIDER shall include movement of key resources and personnel in the BCP.
- 11.11.6 That the SERVICE PROVIDER shall outline a communication plan that includes who to contact and the plan of action in the event of an emergency.

11.12 Compliance and Risk Management

Annex 2 – DITO Data Outsourcing and Information Security Agreement

- 11.12.1 That the SERVICE PROVIDER shall have methods and procedures in place to ensure that it is, and shall continue to be, in compliance with its obligations set forth in this document.
- 11.12.2 That the SERVICE PROVIDER shall establish risk management methodology and carry out information security risk assessment exercises covering all the assets, data, and information present at the SERVICE PROVIDER's site.
- 11.12.3 That the SERVICE PROVIDER shall refer to, implement, and adhere to the following standards, requirements, practices, as may be applicable, to provide DITO reasonable assurance of the SERVICE PROVIDER's compliance with the information security requirements of DITO:
 - 11.12.3.1 ISO 27001 – Information Security Management System Requirements (latest version);
 - 11.12.3.2 ISO 27002: – Code of Practice for Information Security Controls; (latest version)
 - 11.12.3.3 PCI-DSS latest version – Payment Card Industry Data Security Standard;
 - 11.12.3.4 NIST Cybersecurity Framework (latest version);
 - 11.12.3.5 SANS Critical Security Controls (latest version); and
 - 11.12.3.6 ISACA Control Objectives for Information Technologies (COBIT - latest version)
- 11.12.4 That the SERVICE PROVIDER shall seek to align and certify its organization against the requirements of ISO 27001:2013 or the latest version of the aforementioned standard, within twelve (12) months upon being advised or selected by DITO as its service provider.
- 11.12.5 That the SERVICE PROVIDER shall not store, aggregate, and manipulate the data of DITO. The SERVICE PROVIDER shall only use DITO's data and information within the agreed statement of work or any other document, agreed upon by both DITO and the SERVICE PROVIDER that specifically sets out the limitations for the use of such data.
- 11.12.6 That, if found to have access to cardholder-related data or determined to be in-scope for PCI-DSS, the SERVICE PROVIDER shall obtain certification to the latest PCI-DSS requirements within six (6) months upon being advised or selected by DITO as its service provider and shall submit an Attestation of Compliance issued by a PCI-Qualified Security Assessor.
- 11.12.7 That the SERVICE PROVIDER shall engage a qualified security assessor from a reputable firm to be recommended by DITO to conduct an annual independent assessment of the SERVICE PROVIDER's information security management.

Annex 2 – DITO Data Outsourcing and Information Security Agreement

The SERVICE PROVIDER shall provide DITO with a copy of the Assessment Report.

11.12.8 That the SERVICE PROVIDER shall grant DITO and its authorized parties the rights to conduct audit of its organization, sites, and facilities. The audit shall have the following parameters:

11.12.8.1 Frequency: at least once a year

11.12.8.2 Duration: minimum of five days

11.12.8.3 Type: forensics, security/controls review

11.12.8.4 Resource: SERVICE PROVIDER's point of contact to liaise and coordinate with DITO within the SERVICE PROVIDER's organization, sites, and facilities.

11.12.9 That DITO, upon its discretion, may extend its review if needed and the SERVICE PROVIDER shall be expected to heed the request until DITO has been satisfied on the conduct of reviews.

11.12.10 That the SERVICE PROVIDER shall assure DITO of its transparency and readiness to entertain anytime the latter's request for announced or unannounced inspection of SERVICE PROVIDER's organization, sites, facilities, etc. especially during the conduct of an investigation.

11.12.11 That the SERVICE PROVIDER shall notify first the Information Security Officer of DITO to obtain its approval for any planned changes to the current setup of SERVICE PROVIDER's organization, sites, facilities, and other components that may potentially introduce risks.

11.12.12 That the SERVICE PROVIDER shall treat DITO's data or information with utmost confidentiality and shall use it only for the intended purpose that allows the SERVICE PROVIDER to perform its required tasks under the appropriate agreement.

11.12.13 That the SERVICE PROVIDER shall establish and document the disciplinary and consequence management process for handling cases of policy violations, like in the area of information security.

11.12.14 That the SERVICE PROVIDER shall contractually bind its employees, contractors, and service providers in requiring them to surrender, if any, all of the SERVICE PROVIDER's assets in their possession that may potentially contain information of DITO.

11.12.15 That the SERVICE PROVIDER shall establish procedures that will clear an employee or contractor of its accountabilities upon termination of service or end of contract, specifically:

Annex 2 – DITO Data Outsourcing and Information Security Agreement

11.12.15.1 Surrender of company-issued devices

11.12.15.2 Removal of access rights

11.12.15.3 Deletion of data

11.12.16 That the SERVICE PROVIDER shall establish a process to monitor its enforcement and drive the continuous improvement of information security management. At the minimum, the SERVICE PROVIDER shall:

11.12.16.1 Maintain and track the calendar of information security activities;

11.12.16.2 Monitor security-related issues and the progress of their resolution;

11.12.16.3 Establish security metrics;

11.12.16.4 Include information security updates in management meetings; and

11.12.16.5 Initiate continuous improvement program.

11.13 SERVICE PROVIDER Relationships

11.13.1 That the SERVICE PROVIDER shall select each third-party service provider that may have access to any DITO data using a robust and documented SERVICE PROVIDER management process that includes performing due diligence on each potential third-party contractor's ability to comply with the applicable obligations in the appropriate agreement and obtaining such contractual commitments as required for the SERVICE PROVIDER to comply with its obligations under the Agreement.

11.13.2 That the SERVICE PROVIDER shall provide DITO with a quarterly report listing all third-party service providers who may have access to any DITO data, each of their potential access to DITO data, and the type of access that they may have to any DITO data.

11.13.3 That the SERVICE PROVIDER shall notify DITO prior to engaging any external or third party to assist in an investigation of a security incident.

11.13.4 That the SERVICE PROVIDER shall maintain non-disclosure agreements with its personnel, subcontractors and third-party contractors as required by the appropriate agreement.

11.14 Termination of Agreement

11.14.1 That, upon termination of the Agreement for any cause, the SERVICE PROVIDER, without need for demand, shall destroy or return any information or programs, including back-up copies at the SERVICE PROVIDER's disposal, to DITO at the SERVICE PROVIDER's sole cost. The destruction or return of data

Annex 2 – DITO Data Outsourcing and Information Security Agreement

must be witnessed by an authorized representative from DITO and shall be certified as such by both parties.

11.14.2 That the termination of the Agreement by either party shall not affect the accrued rights or remedies of both parties under the Agreement.

11.14.3 That clauses, articles, or schedules that are capable of continuing or that, by their nature, should continue will survive the termination, completion, or repudiation of the Agreement.

12. Addressing Non-conformities to DITO's Privacy and Information Security Requirements

12.1 In the event of any non-conformity on the part of the SERVICE PROVIDER at the time of the signing of this Data Outsourcing and Information Security Agreement, the SERVICE PROVIDER shall prepare and submit a detailed Corrective or Preventive Action Plan with a timeline acceptable to DITO for each SERVICE PROVIDER's non-Conformity to DITO's privacy and information security requirements as specified in Clauses 10 and 11 herein. Such Corrective or Preventive Action Plan shall be submitted within fifteen (15) days from the signing of the Data Outsourcing and Information Security Agreement.

12.2 The SERVICE PROVIDER shall ensure closure of findings, rectification of non-conformities, implementation of agreed recommendations to address the non-conformities within the timeline agreed with DITO.

12.3 For each non-conformity that has not been addressed by the SERVICE PROVIDER within the timeline committed to by the SERVICE PROVIDER to DITO, the SERVICE PROVIDER shall give a rebate to DITO for each non-conformity in the amount equivalent to 0.5% of the total price for the contracted services entered into between SERVICE PROVIDER and DITO.

12.4 Without prejudice to Clause 12.1 above, non-conformities discovered during DITO's audit pursuant to Clause 11.12.8 which are assessed by DITO to be HIGH RISK shall be remediated by the SERVICE PROVIDER within fifteen (15) calendar days from the issuance of a notice from DITO. All other non-conformities shall be remediated within thirty (30) calendar days from the issuance of a notice from DITO. In case the SERVICE PROVIDER cannot remediate within these prescribed periods, the SERVICE PROVIDER must present their remediation plan and timeline to DITO for the latter's concurrence. However, in case of occurrence of any undesirable events resulting from the direct or indirect exploitation of the unresolved non-conformity/ies, the SERVICE PROVIDER shall be liable for any losses or damages that DITO may incur.

13. Indemnification

The SERVICE PROVIDER agrees to irrevocably, unconditionally, and fully indemnify and hold DITO, its officers, employees, and agents, free and harmless from and against any and all claims, suits, actions or demands or losses, damages, costs and expenses including, without limiting the generality of the foregoing, attorney's fees and costs of suit that DITO may face, suffer or incur by reason or in respect of: (a) SERVICE PROVIDER's or its sub-contractor's breach of any of the warranties and obligations set forth in the Data Outsourcing and Information Security Agreement, regardless of the cause of such breach or (b) any act,

Annex 2 – DITO Data Outsourcing and Information Security Agreement

omission, or negligence of the SERVICE PROVIDER or its sub-contractor that causes or results in DITO being in breach of its obligations under the DPA. DITO shall be entitled to liquidated damages in the amount of Two Million Philippine Pesos (PHP 2,000,000.00) for each act, omission, or instance negligence resulting in the breach mentioned herein. Notwithstanding the right to liquidated damages, DITO shall have the right to take any measures available under the law, and to claim and receive a higher amount of compensation if DITO can prove that the actual damage sustained will exceed the amount of liquidated damages claimed.

14. Data Subject Rights

Each Party shall respect the following rights accorded to Data Subjects by the Data Privacy Act of 2012:

- 14.1 **Right to be informed.** Data Subjects have the right to be informed whether Personal Data pertaining to them shall be, are being, or have been processed, including the existence of automated decision-making and profiling. This Agreement may be accessed by the Data Subject upon written request submitted to any of the Parties.
- 14.2 **Right to object.** Data Subjects have the right to object to the processing of their Personal Data, including processing for direct marketing, automated processing, or profiling. They may withhold consent to the processing in case of changes or any amendment to the information supplied or declared to the Data Subject.
- 14.3 **Right to access.** Data Subjects have the right to request access to any of their Personal Data, subject to certain restrictions.
- 14.4 **Right to rectification.** Data Subjects have the right to dispute the inaccuracy or error in the Personal Data and have the personal information controller correct it immediately and accordingly unless the request is vexatious or otherwise unreasonable.
- 14.5 **Right to erasure or blocking.** Data Subjects have the right to suspend, withdraw or order the blocking, removal, or destruction of his or her Personal Data from the personal information controller's filing system.
- 14.6 **Right to damages.** Data Subjects have the right to be indemnified for any damages sustained due to inaccurate, incomplete, outdated, false, unlawfully obtained or unauthorized use of Personal Data, taking into account any violation of the rights and freedoms of the Data Subject.
- 14.7 **Right to lodge a complaint with the NPC.**

15. Communications Regarding Data Privacy and Information Security Concerns

For questions, requests, and notifications, communication may be directed to each Party's designated Data Protection Officer or his/her replacement or substitute.

- **DITO TELECOMMUNITY CORPORATION**

Name: Atty. Roberto Miguel O. Raneses, CIPM
Position: Data Protection Officer
Email Address: dataprivacy@dito.ph

Annex 2 – DITO Data Outsourcing and Information Security Agreement

Name: Col. Roleen Del Prado PA (Ret.)
Position: Information Security Officer
Email Address: infosec@dito.ph

- **[3E HITECH SOLUTIONS, INC.]**

Name: Zenon Miguel De Guzman
Position: General Manager
Email Address: miggy.deguzman@3ehitech.com
Phone Number: 0917 8201634

IN WITNESS WHEREOF, the PARTIES, through their duly authorized representatives, set their signatures this 10th of April at Makati City, Philippines.

Name
Position
**DITO TELECOMMUNITY
CORPORATION**



Name: Benedict P. Cabrera
Position: Sales Account Manager
3E HITECH SOLUTIONS, INC.

APPENDIX 1

DATA OUTSOURCING DETAILS

1. Subject Matter of Processing							
2. Duration of Processing							
3. Purpose(s)							
4. Categories of Data Subjects and Types of Personal Data	<table border="1"><tr><td>Data Subject/s</td><td>Types of Personal Data</td></tr><tr><td></td><td></td></tr><tr><td></td><td></td></tr></table>	Data Subject/s	Types of Personal Data				
Data Subject/s	Types of Personal Data						
5. Geographic Location of the Processing							